

DeepTrustxAI

Private Limited

1

Wazuh SIEM with Log Manthan

Hands-On Workshop – Think Like a Hacker, Defend Like a Pro

Srinidhi

What Will You Learn Today?

- What is a Red Team? (Safe, authorized hacking)
- Simulate real attacks using Atomic Red Team (Windows + Linux)
- Detect attacks as alerts in Wazuh SIEM and Dashboard Query Language (**DQL**)
- Harden systems using **CIS Benchmarks** (prevent before detect)
- Map attacks to **MITRE ATT&CK** framework
- Learn about Compliance Dashboards in Wazuh

Meet the Tools

Tool	Purpose
Atomic Red Team	Library of small, safe attack tests (Windows & Linux)
Wazuh SIEM	Collects logs, generates alerts, MITRE mapping, SCA for CIS
Wazuh Query Language (WQL)	Search/filter alerts like a database
CIS Benchmarks + Compliance dashboards	Hardening guidelines to prevent attacks
Windows + Linux VMs	Target machines

Learn the Jargon

Red Team - A Red Team is a group of cyber security professionals who are *given permission* to think and act like attackers, to find weaknesses in your defenses before a real hacker does.

Atomic Red Team - A free, open-source library of **small, safe, single-purpose attack simulations**, each one tests exactly one technique.

MITRE Attack - MITRE ATT&CK is the universal language of cyberattacks, a publicly maintained encyclopedia of every known attacker tactic and technique, used by defenders worldwide to categorize and communicate threats.

SIEM - Security Information and Event Management, is a security dashboard that collects logs from all the endpoints (computers and servers), then raises alerts when something suspicious happens.

SSH - Secure Shell (SSH) is a network protocol used to securely access and manage a remote computer via Command Line.



The Problem – How Do You Know Your Defenses Work?

- Antivirus and firewalls are not enough
- Hackers are creative – you must test your **detection**
- Waiting for a real attack is too late

The Solution – Adversary Simulation

Definition:

Safely mimicking hacker behavior to see if your security tools alert properly.

Key Benefits:

- No damage to systems
- Verifies your SIEM (Wazuh) rules work
- Teaches your team what an attack looks like

Our Lab Environment (Live Demo Setup)

Components:

1. **Windows VM** – Wazuh agent installed
2. **Linux (Ubuntu) VM** – Wazuh agent installed
3. **Wazuh SIEM dashboard** – Open in browser

Live Demo Prep:

- All agents already connected
- Dashboard empty at start



Example Tactics (What attackers want):

 **Initial Access** – Get in

 **Execution** – Run code

 **Credential Access** – Steal passwords

 **Discovery** – Look around



Scenario 1 – Windows Persistence (Scheduled Task)



What is Persistence?

Attacker ensures they can come back after a reboot.

Atomic Test: T1053.005 – Create a suspicious scheduled task

Command (run on Windows PowerShell as Admin):

Powershell

Invoke-AtomicTest T1053.005

-TestNumbers 1

Expected Wazuh Alert:

- Rule ID: 510
- Description: "Windows Scheduled Task Created"
- MITRE Tactic: Persistence (TA0003)

```
Exit code: 0
Done executing test: T1110.004-4 Brute Force:Credential Stuffing using Kerbrute Tool
PS C:\Windows\system32> Invoke-AtomicTest T1053.005
PathToAtomicFolder = C:\AtomicRedTeam\atomics

Executing test: T1053.005-1 Scheduled Task Startup Script
SUCCESS: The scheduled task "T1053_005_OnLogon" has successfully been created.
SUCCESS: The scheduled task "T1053_005_OnStartup" has successfully been created.
Exit code: 0
Done executing test: T1053.005-1 Scheduled Task Startup Script
Executing test: T1053.005-2 Scheduled task Local
SUCCESS: The scheduled task "spawn" has successfully been created.
Exit code: 0
Done executing test: T1053.005-2 Scheduled task Local
Executing test: T1053.005-3 Scheduled task Remote
ERROR: No mapping between account names and security IDs was done.
Exit code: 1
Done executing test: T1053.005-3 Scheduled task Remote
Executing test: T1053.005-4 Powershell Cmdlet Scheduled Task
-----
TaskPath                                     TaskName                                     State
-----
\                                             AtomicTask                                  Ready
Exit code: 0
Done executing test: T1053.005-4 Powershell Cmdlet Scheduled Task
Executing test: T1053.005-5 Task Scheduler via VBA
New-Object : Retrieving the COM class factory for component with CLSID {00000000-0000-0000-0000-000000000000} failed
due to the following error: 80040154 Class not registered (Exception from HRESULT: 0x80040154 (REGDB_E_CLASSNOTREG)).
At line:70 char:12
+ $app = New-Object -ComObject "$officeProduct.Application"
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [New-Object], COMException
+ FullyQualifiedErrorId : NoCOMClassIdentified,Microsoft.PowerShell.Commands.NewObjectCommand

New-Item : The registry key at the specified path does not exist.
At line:73 char:34
+ if (-not (Test-Path $key)) { New-Item $key }
+ ~~~~~
+ CategoryInfo          : InvalidArgument: (HKEY_CURRENT_US...oft\Office\Word:String) [New-Item], ArgumentException
```


Scenario 2 – Linux Persistence (Backdoor User)



Atomic Test: T1136.001 – Create a local user

Command (run on Linux as root):

Bash

Invoke-AtomicTest T1136.001

Expected Wazuh Alert:

- Rule ID: 5101
- Description: "User added to sudoers" or "User account created"
- MITRE Tactic: Persistence (TA0003)

```
PS /home/waagent> Invoke-AtomicTest T1136.001
PathToAtomicsFolder = /home/waagent/AtomicRedTeam/atomics

Executing test: T1136.001-1 Create a user account on a Linux system
Exit code: 1
Done executing test: T1136.001-1 Create a user account on a Linux system
Executing test: T1136.001-2 Create a user account on a FreeBSD system
Exit code: 127
Done executing test: T1136.001-2 Create a user account on a FreeBSD system
Executing test: T1136.001-6 Create a new user in Linux with `root` UID and GID.
useradd: Permission denied.
useradd: cannot lock /etc/passwd; try again later.
chpasswd: (user butter) pam_chauthtok() failed, error:
Authentication token manipulation error
chpasswd: (line 1, user butter) password not changed
Exit code: 1
Done executing test: T1136.001-6 Create a new user in Linux with `root` UID and GID.
Executing test: T1136.001-7 Create a new user in FreeBSD with `root` GID.
sh: 1: pw: not found
sh: 1: pw: not found
Exit code: 127
Done executing test: T1136.001-7 Create a new user in FreeBSD with `root` GID.
Executing test: T1136.001-10 Create a Linux user via kubectl in a Pod
Exit code: 127
Done executing test: T1136.001-10 Create a Linux user via kubectl in a Pod
```

Challenge – Match the Alert to the Attack



agent.name	rule.mitre.id	rule.mitre.tactic	rule.description	rule.mitre.technique	rule.level	rule.id
Windows_VM_Proxmox	T1098 T1531	Persistence, Impact	User account disabled or deleted	Account Manipulation, Account Access Removal	8	60111
Windows_VM_Proxmox	T1484	Defense Evasion, Privilege Escalation	Domain Users Group Changed	Domain Policy Modification	5	60160
Windows_VM_Proxmox	T1484	Defense Evasion, Privilege Escalation	Administrators Group Changed	Domain Policy Modification	12	60154
Windows_VM_Proxmox	T1087 T1059.001	Discovery, Execution	Discovery activity spawned via powershell execution	Account Discovery, PowerShell	3	92033
Windows_VM_Proxmox	T1087	Discovery	A net.exe account discovery command was initiated	Account Discovery	3	92039
Windows_VM_Proxmox	T1484	Defense Evasion, Privilege Escalation	Administrators Group Changed	Domain Policy Modification	12	60154
Windows_VM_Proxmox	T1098	Persistence	User account changed	Account Manipulation	8	60110
Windows_VM_Proxmox	T1098	Persistence	User account changed	Account Manipulation	8	60110
Windows_VM_Proxmox	T1098	Persistence	User account enabled or created	Account Manipulation	8	60109
Windows_VM_Proxmox	T1098	Persistence	User account enabled or created	Account Manipulation	8	60109
Windows_VM_Proxmox	T1484	Defense Evasion, Privilege Escalation	Domain Users Group Changed	Domain Policy Modification	5	60160
Windows_VM_Proxmox	T1059.001	Execution	Powershell executed "Get-Content -Stream or Invoke-Ex...	PowerShell	4	91837
Windows_VM_Proxmox	T1059.001	Execution	Powershell executed "Get-Content -Stream or Invoke-Ex...	PowerShell	4	91837

Question to audience:

Which Atomic test was likely run?

- A) T1053.005 (Scheduled task)
- B) T1136.001 (Create user)
- C) T1003.001 (LSASS dump)

DQL is Wazuh's built-in search syntax that lets you filter and find specific alerts across thousands of events — like a search engine for your security logs, right inside the dashboard.

Example 1: All T1136 alerts

```
mitre . technique ~ " T1136 "
```

Example 2: High severity alerts (level $\geq$ 10) on Windows

```
agent . name ~ " Windows * " AND rule . level >= 10
```

Example 3: Scheduled task creation

```
rule . description ~ " Scheduled Task " OR win . event_id = " 4698 "
```

Tactic	MITRE ID	Technique Name	OS	What It Does (One Sentence)	Atomic Test Command
Initial Access	T1133	RDP/SSH Exploitation	Windows / Linux	Gains initial access through exposed remote services like RDP, SSH, or VPN.	<code>Invoke-AtomicTest T1133</code>
Execution	T1059.001	PowerShell	Windows	Executes malicious PowerShell commands without an exe file.	<code>Invoke-AtomicTest T1059.001</code>
Persistence	T1053.003	Cron Job	Linux	Creates a cron job to execute malware at scheduled times or system startup.	<code>Invoke-AtomicTest T1053.003</code>
Privilege Escalation	T1548.002	Bypass User Account Control (UAC)	Windows	Elevates privileges without triggering a standard UAC prompt.	<code>Invoke-AtomicTest T1548.002</code>
Defense Evasion	T1070.001	Clear Windows Event Logs	Windows	Removes Windows event logs to hide attacker activity.	<code>Invoke-AtomicTest T1070.001</code>
Discovery	T1083	File and Directory Discovery	Windows / Linux	Searches the file system for sensitive files and directories.	<code>Invoke-AtomicTest T1083</code>
Lateral Movement	T1021.002	SMB / Windows Admin Shares	Windows	Transfers malware via administrative shares and executes it remotely.	<code>Invoke-AtomicTest T1021.002</code>
Collection	T1115	Clipboard Data	Windows / Linux	Captures data copied to the system clipboard.	<code>Invoke-AtomicTest T1115</code>
Exfiltration	T1567	Exfiltration Over Web Service	Windows / Linux	Uploads stolen data to cloud services or web-based platforms.	<code>Invoke-AtomicTest T1567</code>
Impact	T1486	Data Encrypted for Impact	Windows / Linux	Encrypts files to disrupt operations and demand ransom payment.	<code>Invoke-AtomicTest T1486 -TestNumbers 1</code>

What is IT Hygiene?

Definition: The practice of keeping every machine in your network in a **known, clean, and consistent state**.

What Wazuh shows you under IT Hygiene:

Why it matters: Without IT Hygiene, you log into each server *manually* to find problems.

Section	What You See
 System	Hardware info, OS versions — spot forgotten Windows 7 machines
 Software	Every app on every agent — find outdated or vulnerable packages
 Processes	What are executed and running in the endpoint?
 Network	Open ports — a developer machine with SSH open to the world is dangerous
 Identity	All user accounts and groups on all endpoints
 Services	All network destinations and external interactions.

What is CIS?

- **Center for Internet Security** – a global community of experts
- Publishes **best-practice configuration guides** (benchmarks) for Windows, Linux, and more
- Think of it as a **security checklist** for your operating system

Why do we need CIS Benchmarks?

- Default OS settings are often **insecure** (e.g., weak passwords, unnecessary services running)
- Attackers exploit **misconfigurations** – CIS helps you close those gaps
- Many compliance standards (ISO 27001, NIST) **reference CIS** as a baseline

What does CIS help us understand?

- **Level 1 (Basic)**: Easy wins, low operational impact – start here
- **Level 2 (Defense-in-depth)**: Stronger but may affect usability – for high-security environments
- Each control is **testable** – you can check "pass" or "fail"

How do we see CIS in Wazuh?

Wazuh's **SCA (Security Configuration Assessment)** module scans your agents against CIS policies

Scenario: Password complexity policy failing (CIS 5.2.1)

Step 1 – Identify failure in Wazuh SCA: Find check "Password must meet complexity requirements" – Status FAILED.

Step 2 – Apply fix (run live in PowerShell as Admin):

Powershell

```
secedit /export /cfg C:\secpol.cfg
```

```
(Get-Content C:\secpol.cfg) -replace 'PasswordComplexity = 0','PasswordComplexity = 1' | Set-Content C:\secpol.cfg
```

```
secedit /configure /db C:\windows\security\local.sdb /cfg C:\secpol.cfg /areas SECURITYPOLICY
```

Step 3 – Verify: Re-run SCA scan or run `secedit /export` again – now shows PASSED.

Scenario: SSH root login allowed (CIS 5.2.2 – not exactly, but common: "Ensure SSH root login is disabled")

Step 1 – Check current setting (run live):

Bash

```
sudo grep "^PermitRootLogin" /etc/ssh/sshd_config
```

Output: **PermitRootLogin yes** → FAIL.

Step 2 – Apply fix:

Bash

```
sudo sed -i 's/^PermitRootLogin yes/PermitRootLogin no/' /etc/ssh/sshd_config
```

```
sudo systemctl restart sshd
```

Step 3 – Verify:

Bash

```
sudo grep "^PermitRootLogin" /etc/ssh/sshd_config
```

Output: **PermitRootLogin no** → PASSED.

What is a compliance framework?

A set of rules written by regulators or industry bodies (PCI, HIPAA, GDPR, etc.) that tells organizations *exactly* what security controls they must have.

Why do these frameworks exist?

To protect sensitive data – credit cards, medical records, personal info and also to hold companies accountable if they fail.

Who enforces them?

Auditors. They ask one question: **"Prove to us that you're monitoring your systems and protecting sensitive data."**

What happens if you fail?

-  **Fines**
-  **Reputational damage**
-  **Business halt**

Framework	Who It's For	Core Requirement
PCI DSS	Finance / Payments	Log & monitor all access to cardholder data
HIPAA	Healthcare	Audit all access to patient data (ePHI)
GDPR	EU businesses	Protect personal data with documented security controls
NIST 800-53	Government / Federal	Comprehensive security control catalog
TSC / SOC 2	Cloud & SaaS companies	Demonstrate trust service criteria

How does Wazuh help with compliance?

The **compliance dashboards** automatically answer: *"Which regulatory rule does this alert satisfy?"*
They give you **proof for auditors** that your security controls exist and are working.

Key distinction:

- **CIS Benchmarks (SCA)** = Proactive – "Is our configuration secure *before* an attack?"
- **Compliance Dashboards** = Reactive – "Which alerts map to which legal/regulatory rules?"

Scenario: You are a SOC analyst. An alert fires: T1003.001 (Credential Access) from agent HR-PC-01.

Task 1: Identify the HIPAA and PCI rule id's triggered for the T1003.001.

Task 2: Look at the alert details. It says Audit Process Creation is disabled. Which CIS control is failing?

Task 3: Write the command to enable that audit policy on Windows.

Answer Key:

1. HIPAA: §164.312(d) and PCI DSS: Requirements 8 (*These are the primary credential-access tags. You may also see §164.312(b) and PCI Req. 10 on the same alert — that's normal and correct.*)
2. CIS Control 8.2.1 (Audit Process Creation)
3. `auditpol /set /subcategory:"Process Creation" /success:enable /failure:enable`

Now You Can:

- **Run** safe Atomic Red Team tests on Windows **and** Linux
- **Read** a Wazuh alert – rule ID, level, MITRE tactic, raw log
- **Harden** a real CIS failure (password policy, SSH root login)
- **Prove** your fixes work by re-running the attack
- **Understand** the compliance Dashboard

The mindset: *Prevention is cheaper than detection. Detection is cheaper than recovery.*



DeepTrustxAI

QUESTIONS?